

Below is a concise **Module 10**

Compliance Mapping solution that matches the assessment requirement.

Module 10 – Compliance Mapping

Objective

Map key security findings to relevant compliance domains and identify the evidence required to demonstrate compliance or justify a documented exception.

Module 1 Finding	Compliance Domain	Evidence Required
Public Storage	S3/Blob Data Protection	Storage configuration, access policy, encryption enabled, Terraform code
Public Access	Database Network Security	Security Groups/NSGs, firewall rules, private endpoint configuration
Wildcard Permissions	IAM Identity & Access Management	IAM policies, role definitions, least-privilege review, access logs
Missing Logging	Audit Logging & Monitoring	CloudTrail/Azure Activity Logs/GCP Audit Logs, SIEM dashboard, log retention policy
Hardcoded Secrets in Code	Secrets Management	Git history, Secrets Manager/Key Vault configuration, Gitleaks scan report

Compliance Methodology

1. Identify the security finding.
2. Map it to the appropriate compliance domain.
3. Collect technical evidence (Terraform, IAM policies, logs, screenshots, scan reports).
4. Verify compliance or document an approved exception with compensating controls and risk acceptance.

Policy-as-Code (OPA/Conftest)

Instead of maintaining separate rules for AWS, Azure, and GCP, implement a **single OPA/Conftest policy** to validate common security requirements across all cloud providers.

Example controls include:

- Deny public storage resources.
- Require encryption at rest.

- Prevent wildcard (*) IAM permissions.
- Require audit logging to be enabled.
- Enforce resource tagging for governance.

This approach provides:

- **Consistency** across AWS, Azure, and GCP.
- **Automated compliance checks** in the CI/CD pipeline before deployment.
- **Reduced maintenance** through a single reusable policy framework.
- **Continuous compliance** and standardized governance for the multi-cloud environment.

Conclusion

Using a common compliance mapping methodology together with OPA/Conftest enables consistent enforcement of security controls, simplifies governance, and supports scalable compliance across the organisation's AWS, Azure, and GCP environments.